Project 4: Web Application VAPT

Table of Contents

Finding 1: Directory and File Enumeration Using Dirsearch (Low)
Finding 2: Network Service Discovery and Version Enumeration Using Nmap (Low)
Finding 3: SSL Certificate Cannot Be Trusted (Medium)
Finding 4: TLS Version 1.0 Protocol Detection (Medium)
Finding 5: SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits – Logjam (Low)
Finding 6: Sensitive Directory Enumeration Using Gobuster (Low)
Finding 7: Web Technology Fingerprinting Using WhatWeb (Low)
Finding 8: WHOIS Information Disclosure (Low)
Finding 9: Subdomain Enumeration Using Sublist3r (Medium)
Finding 10: Information Gathering Using theHarvester (Low)
Finding 11: Technology Fingerprinting Using Wappalyzer
Finding 12: Parameter Tampering Leading to Unauthorized Fund Transfer (High)

1. **Title:** Directory and File Enumeration Using Dirsearch

Severity: Low

CWE: CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor

CVSS: 2.6 (Low)

OWASP Top 10: A05:2021 – Security Misconfiguration

Description

A directory enumeration scan was performed against the target application using Dirsearch. The scan identified multiple administrative directories, login pages, API endpoints, Swagger documentation, static resources, and application files. Most administrative resources returned **HTTP 302 (Redirect)** responses to the login page, indicating that authentication is enforced, while some pages such as **/search.jsp**, **/feedback.jsp**, and **/swagger/index.html** returned **HTTP 200**, confirming that they are publicly accessible. The **/api/application.wadl** endpoint returned **HTTP 401 (Unauthorized)**, indicating that authentication is required.

Business Impact

The discovery of hidden directories and administrative endpoints provides attackers with valuable reconnaissance information about the application's internal structure. These endpoints may become targets for authentication bypass, brute-force attacks, access control testing, or API security assessments. Although no direct vulnerability was confirmed during directory enumeration, exposing such resources increases the application's attack surface and can aid attackers in planning further exploitation.

Tool Used: Dirsearch v0.4.3

Target

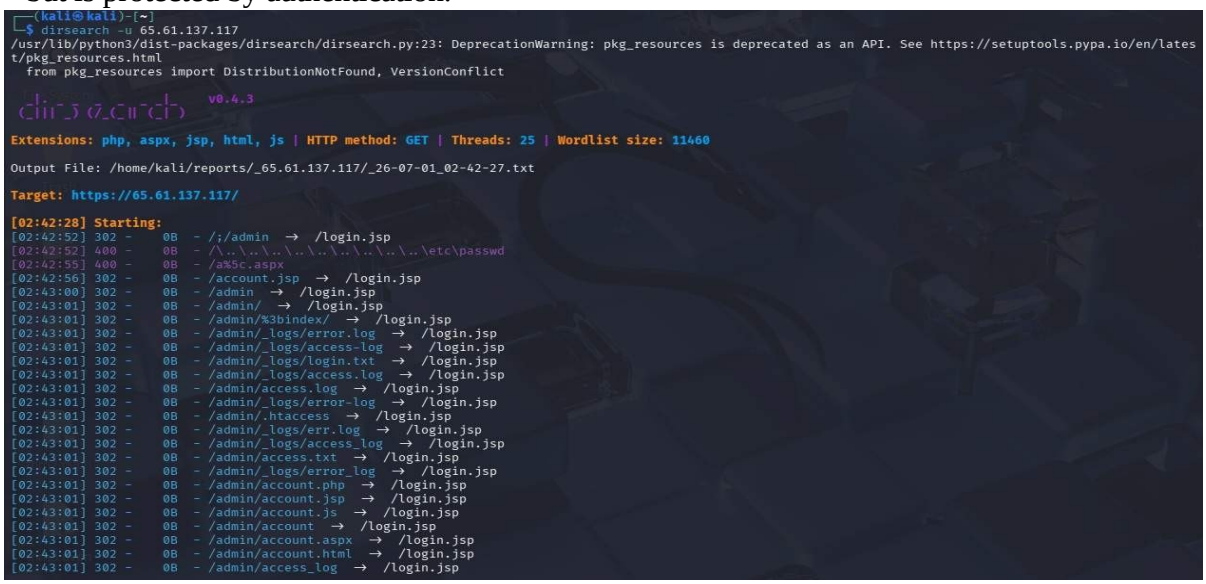
https://65.61.137.117/

Proof of Concept (PoC)

Directory enumeration was performed against the target web application using the **Dirsearch** tool to identify hidden directories, administrative interfaces, API endpoints, and publicly accessible resources. The scan used the default wordlist to brute-force common directory and file names on the target application.

During the scan, several interesting resources were identified. Multiple administrative directories such as **/admin**, **/admin/login.jsp**, **/admin/account.jsp**, and **/admin/upload.php** responded with **HTTP 302 (Redirect)**, indicating that these resources exist but require authentication. Publicly accessible

resources including **/search.jsp**, **/feedback.jsp**, and **/swagger/index.html** returned **HTTP 200 (OK)** responses, confirming that these pages are accessible without authentication. The endpoint **/api/application.wadl** returned **HTTP 401 (Unauthorized)**, indicating that the API definition exists but is protected by authentication.





Remediation

- Restrict access to administrative directories.
- Disable or remove unnecessary development endpoints.
- Protect Swagger documentation behind authentication.
- Restrict access to API documentation files.
- Return generic responses for unauthorized resources where appropriate.
- Periodically review exposed directories and files.

Conclusion

The Dirsearch scan **did not confirm any exploitable vulnerability**. However, it

successfully identified several administrative and application-specific endpoints that may require further manual testing for issues such as Broken Access Control, Authentication Weaknesses, IDOR, File Upload vulnerabilities, or API Misconfigurations.

2. Title: Network Service Discovery and Version Enumeration Using Nmap

Severity: Low

CWE: CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor

CVSS: 2.6 (Low)

OWASP Top 10: A05:2021 – Security Misconfiguration

Description

An advanced Nmap (-A) scan was performed against the target host to identify open ports, running services, service versions, operating system details, SSL certificate information, HTTP server headers, and network path information. The scan identified several publicly accessible services including HTTP (80), HTTPS (443), and HTTP Proxy (8080). Banner information revealed the web server software, while OS detection suggested the target is likely running a Microsoft Windows Server platform. Traceroute results also revealed the network path to the destination server.

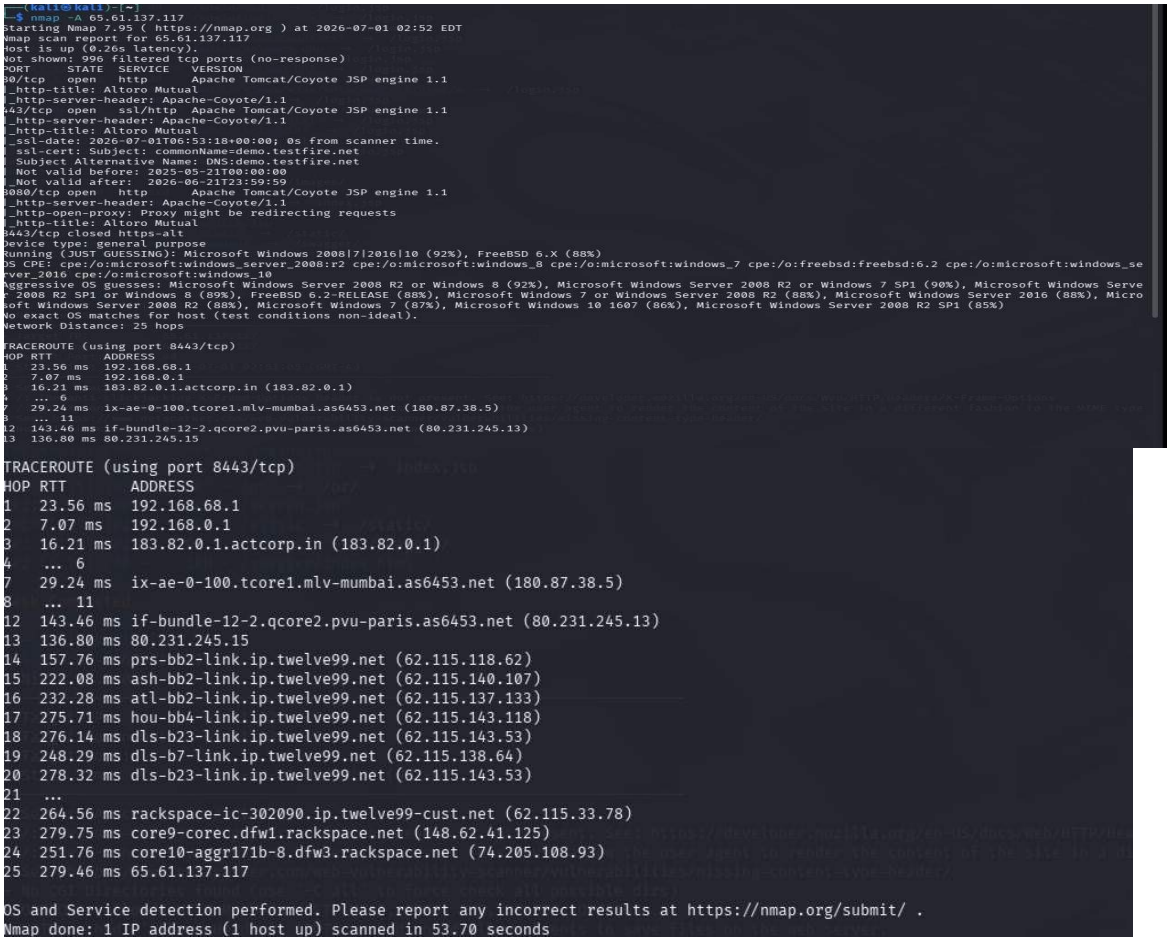
Business Impact

Service and version enumeration provide attackers with valuable reconnaissance information regarding the target infrastructure. Information such as operating system versions, web server software, open ports, SSL certificate details, and network topology can assist attackers in identifying known vulnerabilities and planning targeted attacks. Although no direct exploitation was performed, the exposed service information increases the attack surface and should be minimized where possible.

Target IP Address: 65.61.137.117

Proof of Concept (PoC)

An advanced Nmap scan was executed using the **-A** option to perform comprehensive service enumeration. This scan identified open ports, detected running services, retrieved service banners, attempted operating system fingerprinting, collected SSL certificate information, and performed traceroute analysis. The scan confirmed that the target exposes HTTP and HTTPS services running on Apache Tomcat/Coyote JSP Engine and provided valuable information regarding the server configuration and network path. Although no exploitable vulnerability was confirmed during this phase, the collected information can be used during subsequent vulnerability assessment and penetration testing activities.



Remediation

- Disable unnecessary service banner disclosure.
- Keep Apache Tomcat updated to the latest supported version.
- Disable unused network services and ports.
- Harden SSL/TLS configurations by supporting only modern protocols and strong cipher suites.
- Implement security headers such as **X-Frame-Options**, **Content-Security-Policy**, and **X-Content-Type-Options**.
- Regularly perform vulnerability assessments to identify outdated software and insecure configurations.

Conclusion

The Nmap scan **did not identify any confirmed exploitable vulnerabilities**. However, it successfully gathered detailed information about the target's exposed services, operating system, SSL certificate, and network configuration. These findings represent valuable reconnaissance information that should be considered during further penetration testing and security hardening activities.

3. Title: SSL Certificate Cannot Be Trusted

Severity: Medium

CVSS v3.0: 6.5 (Medium)

CWE: CWE-295 – Improper Certificate Validation

OWASP Top 10: A02:2021 – Cryptographic Failures

Tool Used: Tenable Nessus Essentials

Description

A Nessus vulnerability assessment identified that the SSL/TLS certificate presented by the target web server cannot be fully trusted. The certificate chain contains an expired certificate, causing the trust chain to be invalid. During the assessment, the certificate associated with **demo.testfire.net** was found to have expired on **21 June 2026**, making it unsuitable for establishing a trusted encrypted connection.

An untrusted or expired certificate prevents clients from validating the authenticity of the server. This may expose users to Man-in-the-Middle (MITM) attacks, certificate spoofing, and interception of encrypted communications. Modern browsers may display certificate warnings, reducing user confidence and affecting secure communication with the application.

Business Impact

The use of an expired or untrusted SSL certificate can significantly impact the confidentiality and integrity of communications between clients and the web server. Users may receive browser security warnings, which can reduce trust in the application and discourage legitimate usage. Attackers may exploit the broken trust chain to perform certificate spoofing or Man-in-the-Middle attacks, potentially intercepting sensitive information such as user credentials, session cookies, or confidential business data. In production environments, this issue may also result in non-compliance with organizational security policies and industry standards.

Proof of Concept (PoC)

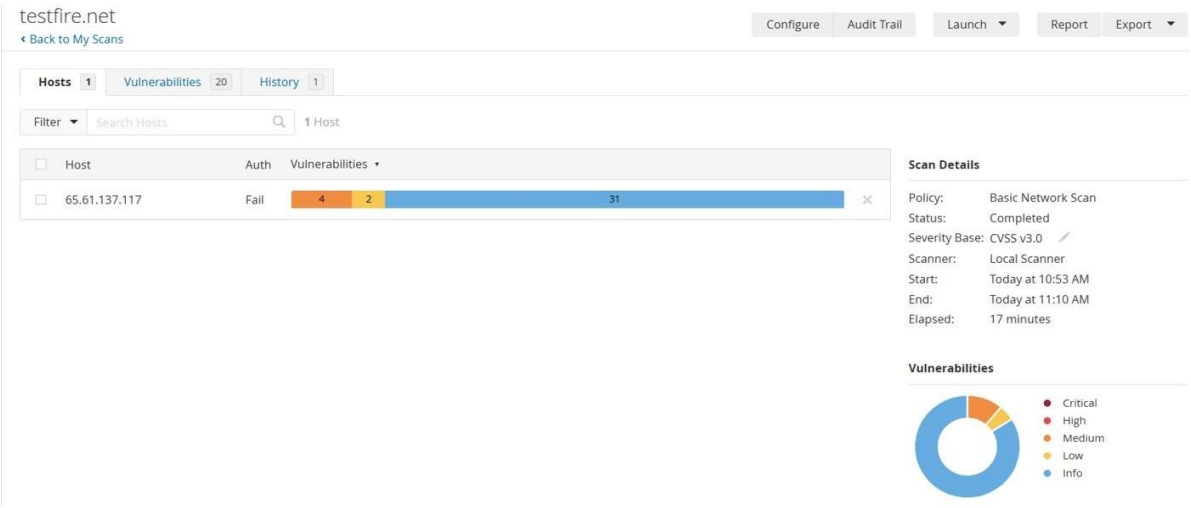
A Nessus Basic Network Scan was performed against the HTTPS service running on **65.61.137.117**. During SSL/TLS certificate validation, Nessus identified that the certificate chain contained an expired certificate. The scan output revealed that the certificate issued for **CN=demo.testfire.net** had exceeded its validity period, causing the certificate chain to become untrusted.

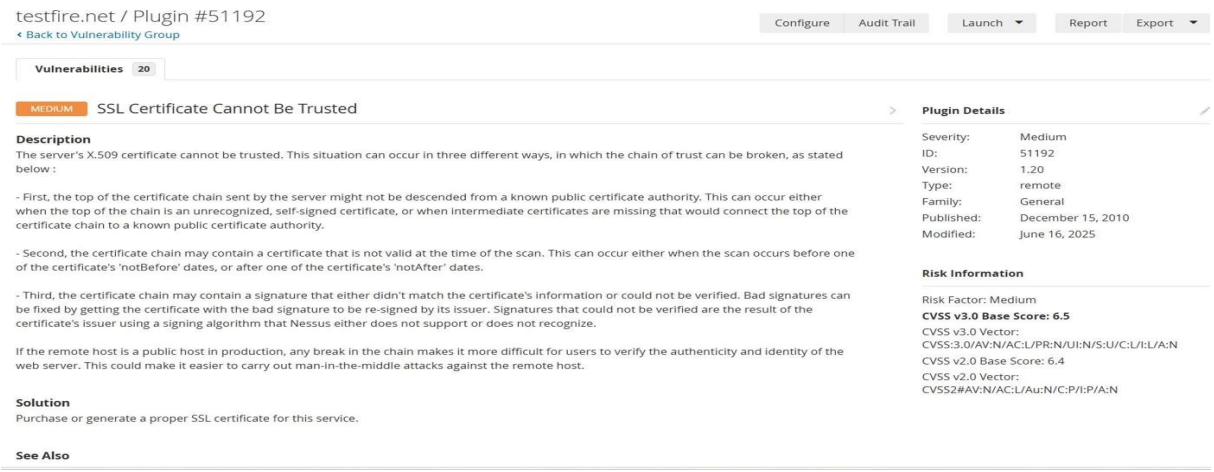
The plugin verified the certificate information and reported the following:

- Host: **65.61.137.117**
- Port: **443/tcp**
- Common Name (CN): **demo.testfire.net**
- Certificate Expiration Date: June 21 23:59:59 2026 GMT

- Nessus Plugin
  ID: 51192

Because the certificate chain cannot be successfully validated, clients connecting to the HTTPS service may receive browser warnings indicating that the server identity cannot be verified.







Risk

- Man-in-the-Middle (MITM) attacks
- Loss of encrypted communication trust
- Browser security warnings
- Certificate spoofing attacks
- Reduced user confidence

Remediation

- Replace the expired SSL certificate with a valid certificate issued by a trusted Certificate Authority (CA).
- Ensure that the complete certificate chain, including intermediate certificates, is correctly installed on the web server.
- Configure automatic certificate renewal to prevent future expirations.
- Continuously monitor certificate validity and expiration dates.
- Verify SSL/TLS configuration after certificate replacement.

Conclusion

The Nessus assessment identified that the target web server is using an **untrusted SSL certificate** because the certificate chain contains an **expired certificate**. Although the HTTPS service is operational, users cannot reliably verify the authenticity of the server, increasing the risk of secure communication failures and potential Man-in-the-Middle attacks. Replacing the expired certificate with a valid certificate issued by a trusted Certificate Authority will restore secure communication and eliminate this vulnerability.

4. Title: TLS Version 1.0 Protocol Detection

Severity: Medium

CVSS v3.0: 6.5 (Medium)

CWE: CWE-327 – Use of a Broken or Risky Cryptographic Algorithm

OWASP Top 10: A02:2021 – Cryptographic Failures

Tool Used: Tenable Nessus Essentials

Description

A Nessus vulnerability assessment identified that the target HTTPS service still supports **TLS Version 1.0**, an outdated cryptographic protocol that has been deprecated due to multiple known security weaknesses. Although TLS 1.0 provides encrypted communication, it lacks support for modern cryptographic protections available in newer protocols such as **TLS 1.2** and **TLS 1.3**.

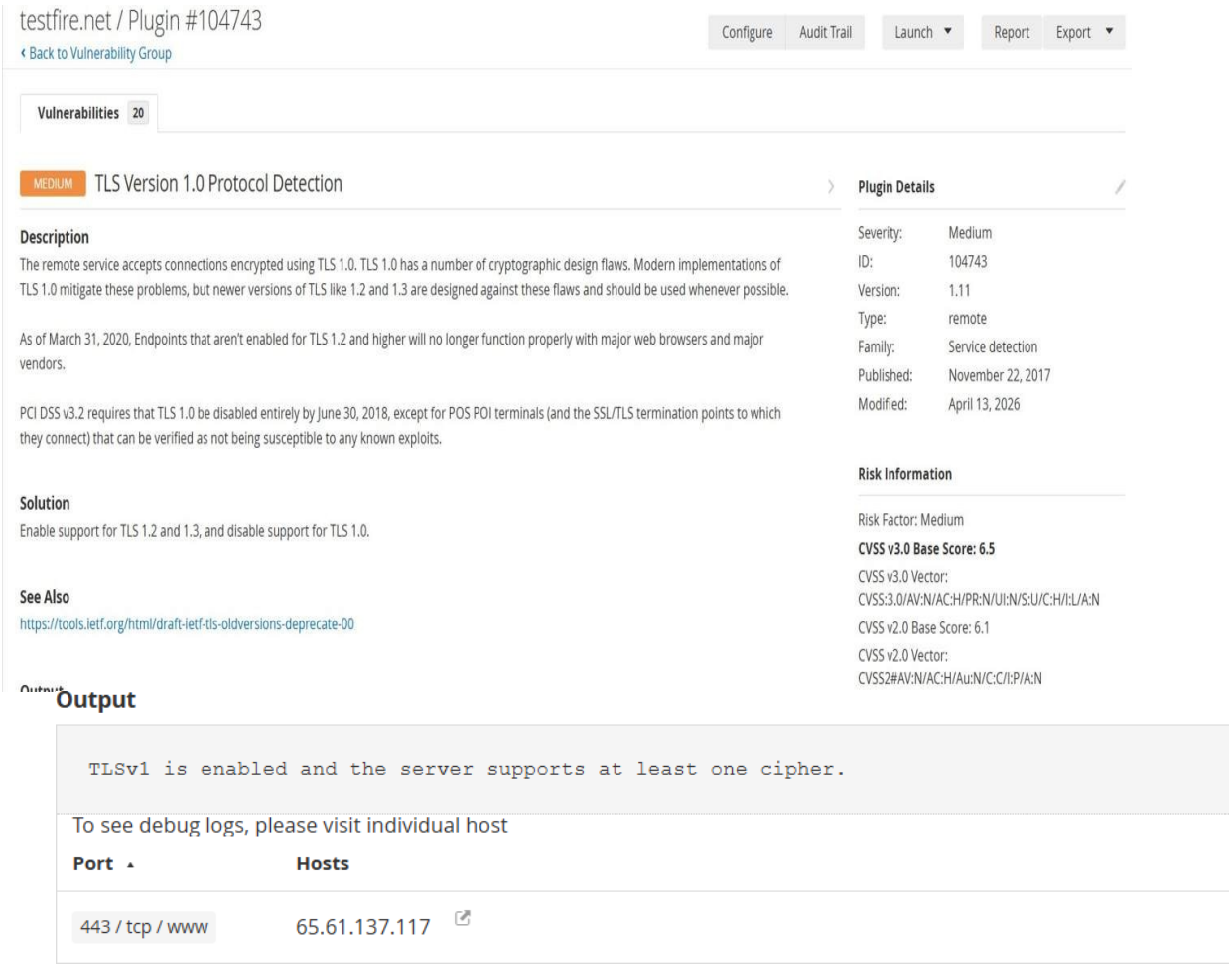
The scan confirmed that **TLSv1 is enabled and the server supports at least one cipher suite**, indicating that legacy clients can establish encrypted sessions using this deprecated protocol. Since TLS 1.0 has reached end-of-life and is no longer considered secure by industry standards, its continued use exposes the application to known cryptographic attacks and compliance risks.

Business Impact

Allowing TLS 1.0 connections weakens the security of encrypted communications between users and the web application. Attackers may exploit weaknesses in deprecated TLS implementations to perform cryptographic attacks against encrypted sessions. Continued support for outdated protocols may also lead to regulatory non-compliance with standards such as **PCI DSS**, which requires the use of modern encryption protocols. Additionally, modern browsers and client applications may refuse connections using TLS 1.0, potentially impacting application availability and user trust.

Proof of Concept (PoC)

A Nessus **Basic Network Scan** was performed against the HTTPS service running on **65.61.137.117**. During the SSL/TLS assessment, Nessus successfully negotiated a connection using **TLS Version 1.0**, confirming that the server still accepts connections over this deprecated protocol.



Risk

- Use of deprecated cryptographic protocol.
- Increased exposure to known TLS attacks.
- Weak encryption for client-server communication.
- Non-compliance with PCI DSS and modern security standards.
- Reduced compatibility with modern browsers and applications.

Remediation

- Disable support for **TLS Version 1.0** on the web server.
- Enable only **TLS Version 1.2** and **TLS Version 1.3**.
- Remove weak cipher suites associated with legacy TLS versions.
- Update the web server and SSL/TLS configuration to follow current industry best practices.
- Regularly audit SSL/TLS configurations using vulnerability assessment tools.

Conclusion

The Nessus assessment identified that the target server continues to support **TLS Version**

1.0, which is considered a deprecated and insecure cryptographic protocol. Although encrypted communication is available, the use of legacy TLS weakens transport security and may expose users to known cryptographic attacks. Disabling TLS 1.0 and enforcing TLS 1.2 or TLS 1.3 will significantly improve the security of encrypted communications and ensure compliance with current security standards.

5. Title: SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)

Severity: Low

CVSS v3.0: 1.4 (Low)

CWE: CWE-326 – Inadequate Encryption Strength
OWASP Top 10: A02:2021 – Cryptographic Failures

Description

The Nessus scan identified that the target server supports **Diffie-Hellman (DH) key exchange using a 1024-bit modulus**. This configuration is associated with the **Logjam attack**, where weak DH parameters reduce the strength of the TLS key exchange process.

The scan output shows that **TLSv1.0** is enabled with the cipher suite **TLS_DHE_RSA_WITH_AES_256_CBC_SHA**, using a **1024-bit Diffie-Hellman MODP Group 2**. Although exploiting this weakness requires significant computational resources, it represents a cryptographic weakness because modern security standards recommend **2048-bit or stronger** Diffie-Hellman parameters.

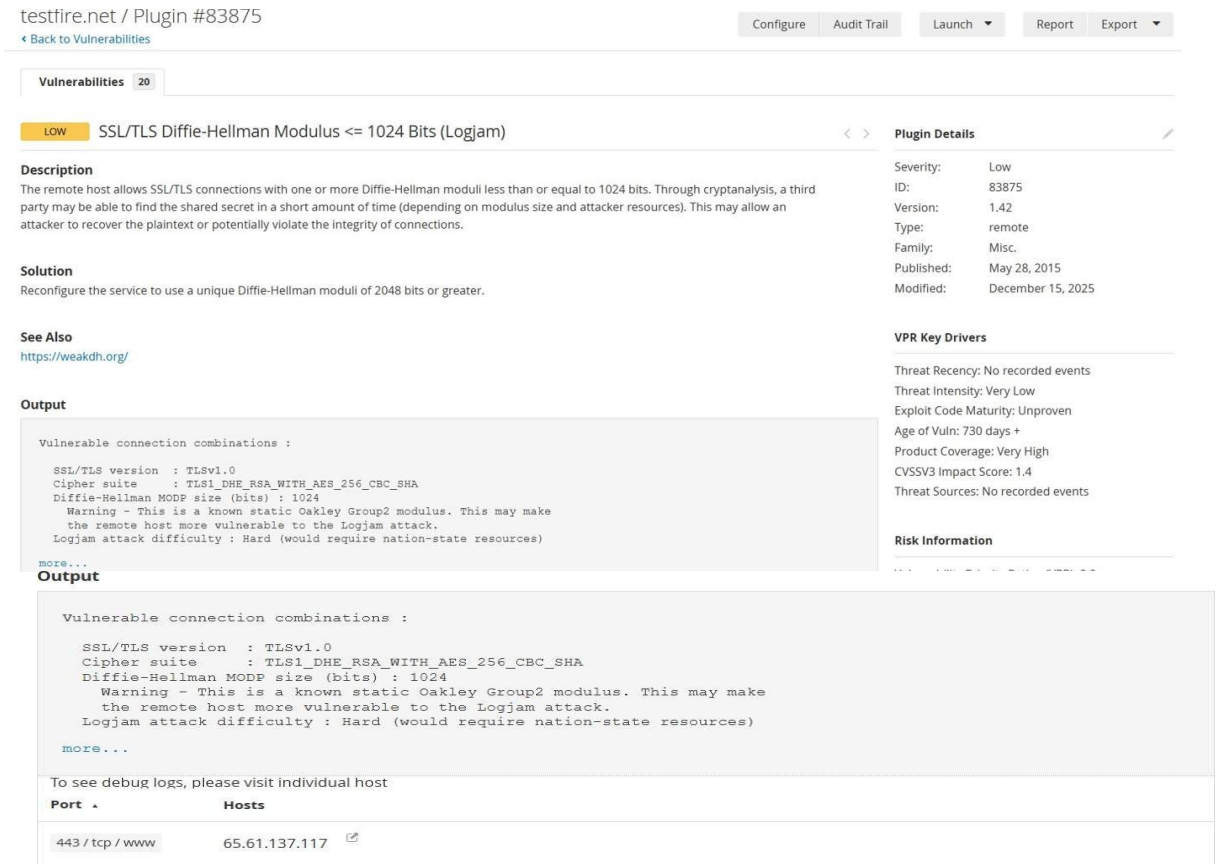
Weak cryptographic configurations can reduce the confidentiality of encrypted communications and do not comply with current industry best practices.

Business Impact

- Weak Diffie-Hellman parameters reduce the overall strength of encrypted HTTPS communications.
- Sensitive information transmitted over TLS could become more vulnerable if cryptographic attacks become feasible.

Proof of Concept (POC)

During the Nessus Basic Network Scan, Plugin **83875** identified that the HTTPS service running on **65.61.137.117:443** supports **TLSv1.0** using the cipher suite:



Remediation

- Replace **1024-bit Diffie-Hellman** parameters with **2048-bit or stronger** parameters.
- Disable weak DHE cipher suites where they are no longer required.
- Enable only modern TLS versions (TLS 1.2 and TLS 1.3).
- Remove outdated cipher suites supporting weak key exchange mechanisms.
- Periodically review SSL/TLS configurations using vulnerability scanners and SSL assessment tools.

Conclusion

The Nessus assessment identified that the HTTPS service on **65.61.137.117** uses **1024-bit Diffie-Hellman parameters**, making it susceptible to the **Logjam** cryptographic weakness. While the vulnerability is rated **Low** because exploitation is difficult, it represents an outdated and insecure cryptographic configuration. Upgrading to stronger Diffie-Hellman parameters (2048 bits or higher) and adopting modern TLS configurations will significantly improve the security of encrypted communications.

6. Title: Sensitive Directory Enumeration Using Gobuster
Severity: Low
CWE: CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor

OWASP Top 10: A05:2021 – Security Misconfiguration

Domain Name - http://testfire.net

Description

Gobuster directory enumeration was performed against http://testfire.net using the **common.txt** wordlist. The scan identified multiple accessible and redirected directories, including administrative and application-related paths. Several directories returned **HTTP 302 redirects** to the login page, indicating that these resources exist but require authentication. Other directories returned **HTTP 200**, confirming that they are reachable by the web server. Although this output does not confirm an exploitable vulnerability, it exposes the application's directory structure. Such information can assist attackers during the reconnaissance phase by identifying administrative panels, static resources, and application modules that may become targets for further testing.

Business Impact

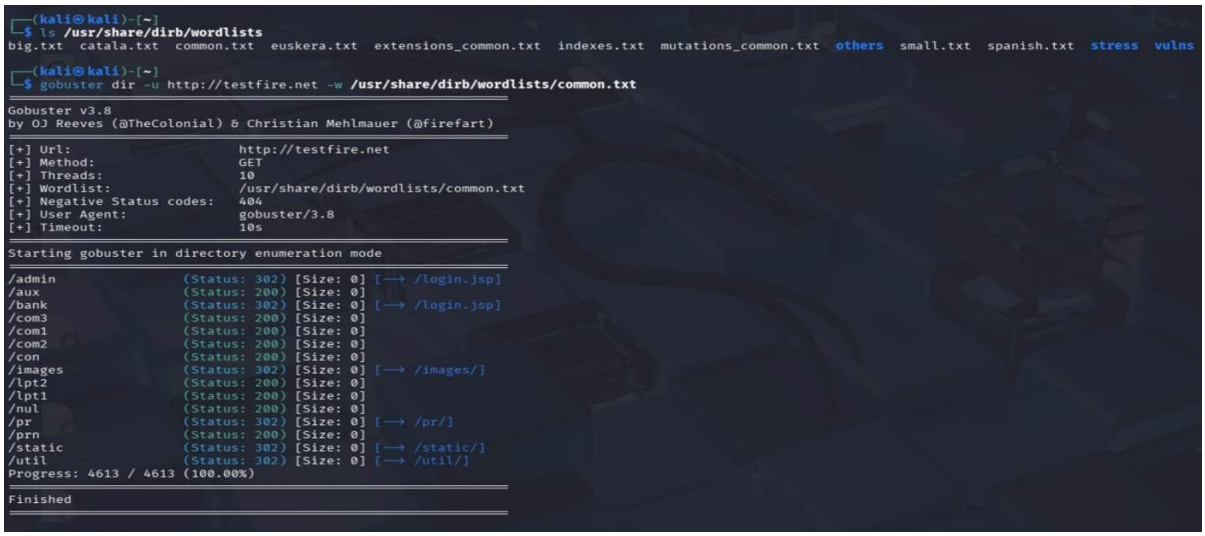
- Reveals internal application structure to unauthenticated users.
- Administrative endpoints become easier to identify.
- Attackers can focus testing on valid application paths.
- Publicly exposed directories increase the application's attack surface.
- Information disclosure during reconnaissance may facilitate future attacks if combined with other vulnerabilities.

Proof of Concept (POC)

Gobuster was executed using the following command:

gobuster dir -u http://testfire.net -w /usr/share/dirb/wordlists/common.txt

The scan successfully completed directory enumeration using **4,613** entries from the supplied wordlist.



Remediation

- Restrict unnecessary public access to administrative directories.
- Configure the web server to return generic responses where appropriate to reduce information disclosure.
- Review exposed directories and remove unused or legacy endpoints.
- Implement strong authentication and authorization for sensitive resources.
- Periodically perform directory enumeration assessments to identify newly exposed paths.

Conclusion

The Gobuster directory enumeration successfully identified multiple valid application directories and administrative endpoints on **testfire.net**. While this finding does **not** represent a confirmed vulnerability by itself, it exposes valuable information about the application's structure that could aid an attacker during reconnaissance. Proper access controls and minimizing unnecessary exposure of application directories can help reduce the overall attack surface.

7. Title: Web Technology Fingerprinting Using WhatWeb

Severity: Low

CWE: CWE-200 – Exposure of Information

OWASP Top 10: A05:2021 – Security Misconfiguration

Description

The **WhatWeb** scan was performed against http://testfire.net to identify the technologies used by the web application. The scan detected that the application is running on an **Apache** web server with **Apache-Coyote/1.1**, uses **Java**, and sets a **JSESSIONID** cookie. This information helps in understanding the application's technology stack during the reconnaissance phase.

Business Impact

Technology fingerprinting may provide attackers with information about the server and application framework, allowing them to identify known vulnerabilities and plan targeted attacks.

Proof of Concept (POC)

The WhatWeb scan was executed against the

target (see the screenshot below) and

identified:

- Apache Web Server
- Apache-Coyote/1.1
- Java Technology
- JSESSIONID Cookie
- HTTP Status: 200 OK
- Target IP: 65.61.137.117



Remediation

- Disable unnecessary server version disclosure.
- Keep the web server and application components updated.
- Minimize publicly exposed technology information through HTTP headers.

Conclusion

The scan successfully identified the technologies used by the target application. While this is **not a direct vulnerability**, it provides useful reconnaissance information that could assist attackers in identifying potential attack vectors.

8. Title: WHOIS Information Disclosure (Domain Enumeration)

Severity: Low

CWE: CWE-200 – Exposure of Information

OWASP Top 10: A05:2021 – Security Misconfiguration

Description

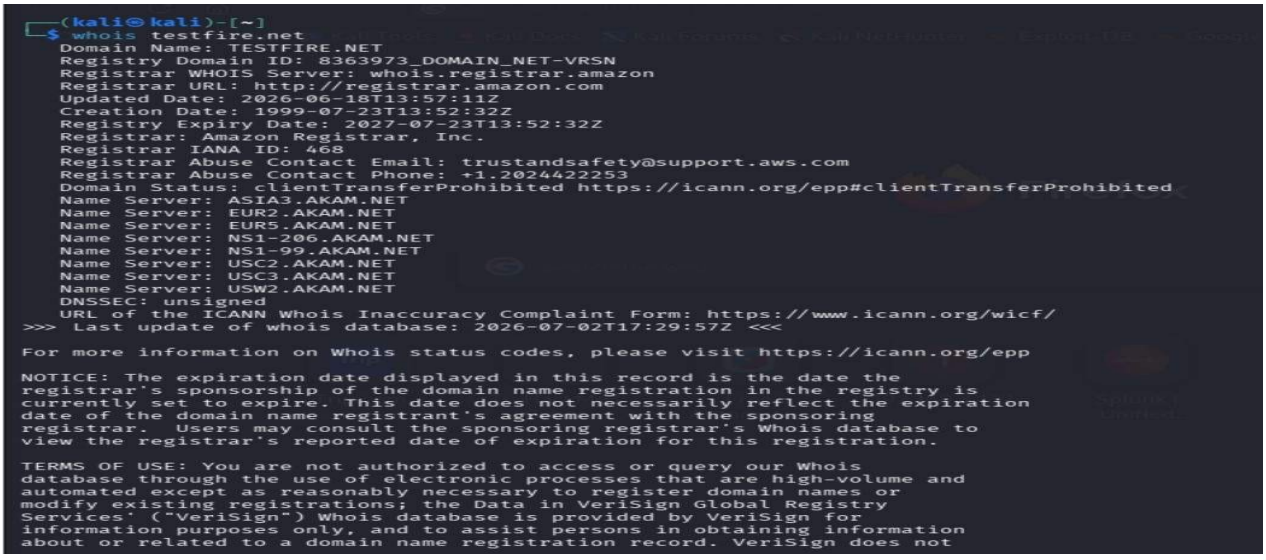
A WHOIS lookup was performed against testfire.net to collect publicly available domain registration information. The scan revealed details such as the domain registrar, registration dates, expiry date, name servers, and domain status. This information is commonly gathered during the reconnaissance phase to understand the target environment.

Business Impact

Public WHOIS information can assist attackers in gathering intelligence about the target domain. This information may be used to plan phishing, social engineering, or infrastructure mapping attacks when combined with other reconnaissance data.

Proof of Concept (POC)

A WHOIS lookup was performed using the command **whois testfire.net** to gather publicly available domain registration information. The scan successfully identified details such as the registrar, domain creation and expiry dates, name servers, and domain status, confirming the availability of publicly accessible domain metadata.



Remediation

- Ensure only necessary WHOIS information is publicly available.
- Use registrar privacy protection where applicable.

- Regularly review domain registration details and keep them updated.

Conclusion

The WHOIS lookup successfully collected publicly available domain registration information for testfire.net. While this is not a security vulnerability, it provides reconnaissance information that may assist attackers during the initial information-gathering phase of an assessment.

9. Title: Subdomain Enumeration Using Sublist3r

Severity: Medium

CWE: CWE-200 – Exposure of Information

OWASP Top 10: A05:2021 – Security Misconfiguration

Description

A subdomain enumeration scan was performed against **testfire.net** using **Sublist3r**. The scan identified **five publicly accessible subdomains**, which can be used during the reconnaissance phase to understand the organization's attack surface. Some data sources (DNSDumpster and VirusTotal) failed due to service restrictions, but the scan still successfully discovered multiple valid subdomains.

Business Impact

Publicly accessible subdomains increase the organization's attack surface. If any subdomain is misconfigured, outdated, or improperly secured, it could become an entry point for attackers.

Proof of Concept (POC)

The following command was executed:

sublist3r -d testfire.net

The scan successfully discovered the following subdomains:

- www.testfire.net
- altoro.testfire.net
- demo.testfire.net
- demo2.testfire.net
- ftp.testfire.net



Remediation

- Regularly review all public subdomains.
- Remove unused or deprecated subdomains.
- Ensure each subdomain is securely configured and updated.
- Continuously monitor subdomains for unauthorized changes or exposure.

Conclusion

The Sublist3r scan successfully identified five public subdomains associated with testfire.net. This is not a confirmed vulnerability, but it is valuable reconnaissance information that can be used for further security assessment and attack surface analysis.

10. Title: Information Gathering Using theHarvester

Severity: Low

CWE: CWE-200 – Exposure of Information

CVSS: 1.4 (Low)

OWASP Top 10: A05:2021 – Security Misconfiguration

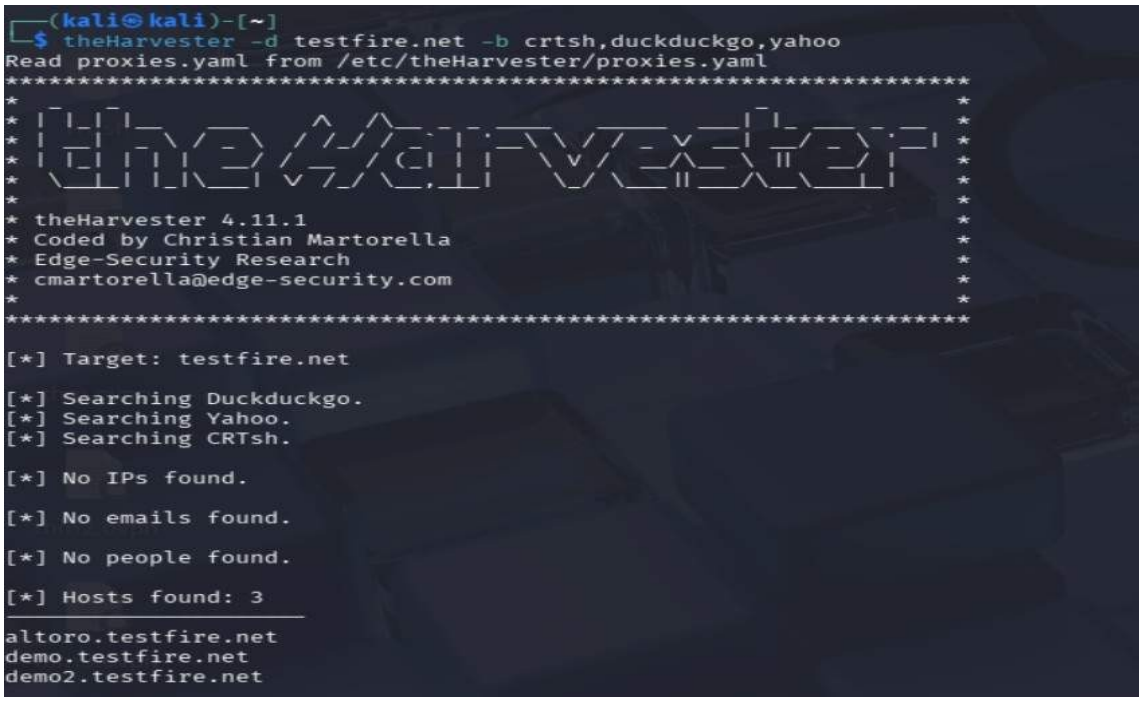
Description

The **theHarvester** tool was used to perform passive reconnaissance on testfire.net by querying public sources such as DuckDuckGo, Yahoo, and CRT.sh. The scan did not identify any public email addresses, IP addresses, or employee information. However, it successfully discovered three valid subdomains, indicating publicly accessible assets associated with the target domain.

Business Impact

Publicly accessible subdomains increase the organization's attack surface. Attackers may use these subdomains for further reconnaissance and security testing to identify misconfigurations or exposed services.

Proof of Concept (POC) : The scan identified three public subdomains (`altoro.testfire.net`, `demo.testfire.net`, and `demo2.testfire.net`) while no public emails, IP addresses, or personnel information were found.



Remediation

- Regularly monitor publicly exposed subdomains.
- Remove unused or inactive subdomains.
- Ensure all discovered subdomains follow secure configuration and patch management practices.

Conclusion

The theHarvester scan successfully identified three public subdomains associated with testfire.net. No sensitive information such as email addresses or employee details was exposed. This is an Informational Finding and serves as reconnaissance data rather than a confirmed security vulnerability.

11. Title: Technology Fingerprinting Using Wappalyzer

Description:

Wappalyzer was used to identify the technologies powering the target web application. The assessment identified the web server, programming language, JavaScript libraries, and other technologies. This information is useful for understanding the application's architecture and planning further security testing.

Business Impact:

Technology disclosure may assist an attacker in selecting appropriate attack techniques if outdated or vulnerable software versions are present.

Procedure:

1. Open Wappalyzer.
2. Visit the target application.
3. Analyze the detected technologies.
4. Document the identified components.

Remediation:

- Avoid exposing unnecessary technology information.
- Keep software and frameworks updated.
- Remove or minimize technology disclosure where possible.

12. Title: Parameter Tampering Leading to Unauthorized Fund Transfer (Business Logic Vulnerability)

CWE: CWE-472 – External Control of Assumed-Immutable Web Parameter

Severity: High

CVSS v3.1: 8.8 (High)

OWASP Top 10: A01:2021 – Broken Access Control

Description

During testing of the **Transfer Funds** functionality in the Altoro Mutual application, it was observed that critical transaction parameters (fromAccount, toAccount, and transferAmount) were transmitted directly in the HTTP POST request. The request was intercepted in Burp Suite and the **transferAmount** parameter was modified before forwarding it to the server. The server processed the altered request and completed the transfer without rejecting or revalidating the modified value, indicating insufficient server-side validation of security-sensitive parameters.

Business Impact

- Unauthorized modification of transaction values.
- Financial loss due to manipulated transfers.
- Compromise of transaction integrity.
- Loss of customer trust.
- Regulatory and compliance risks.
- Increased risk of fraud if exploited by an authenticated attacker.

Procedure

5. Logged in to the Altoro Mutual application.
6. Navigated to **Transfer Funds**.
7. Entered the transfer details and submitted the request.
8. Intercepted the POST request using Burp Suite Proxy.
9. Sent the request to Burp Repeater.
10. Modified the `transferAmount` parameter from the original value to a different value.
11. Forwarded the modified request.
12. Observed that the application accepted the modified parameter and processed the transaction successfully.

Domain Name

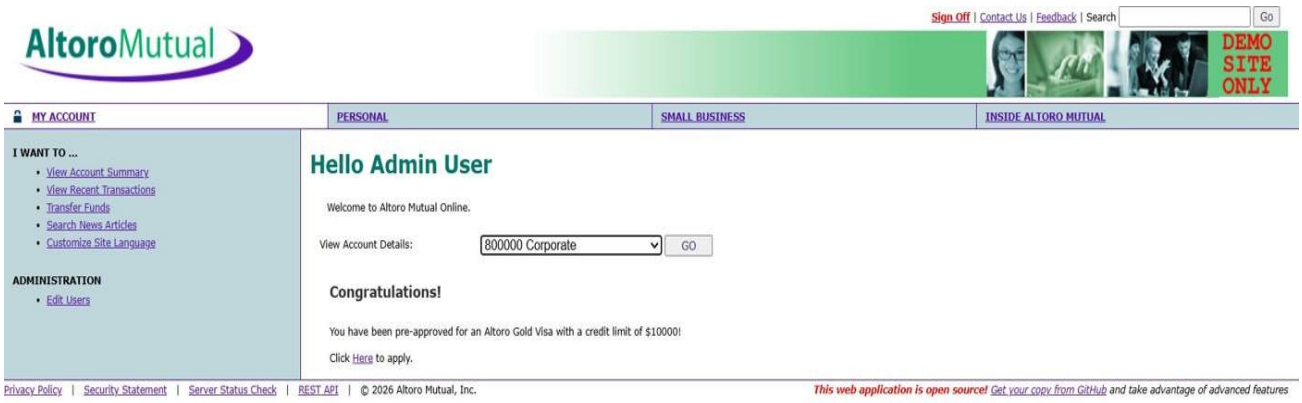
http://testfire.net

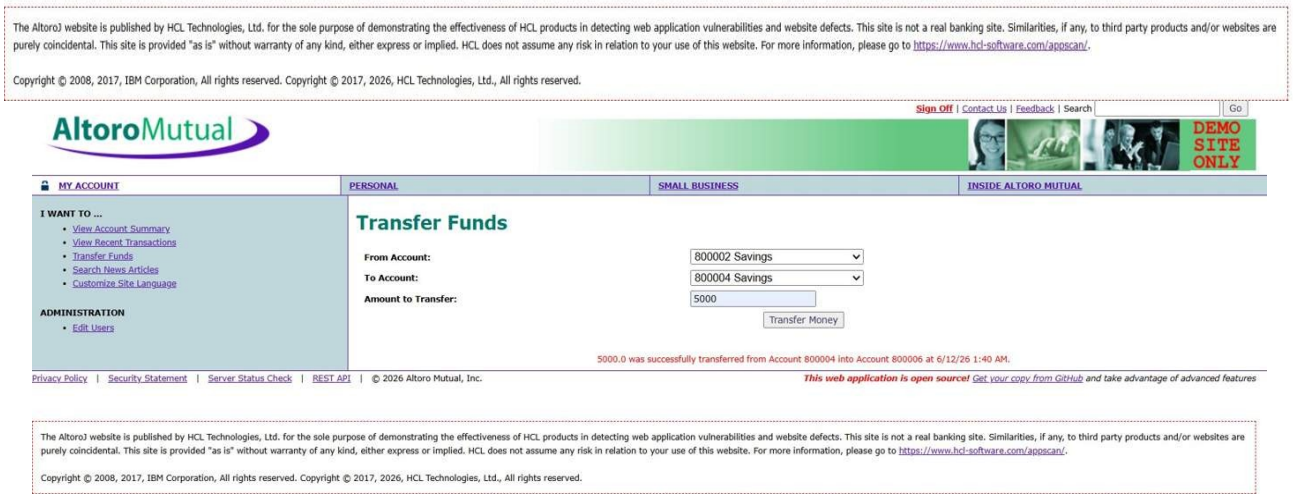
Affected URL

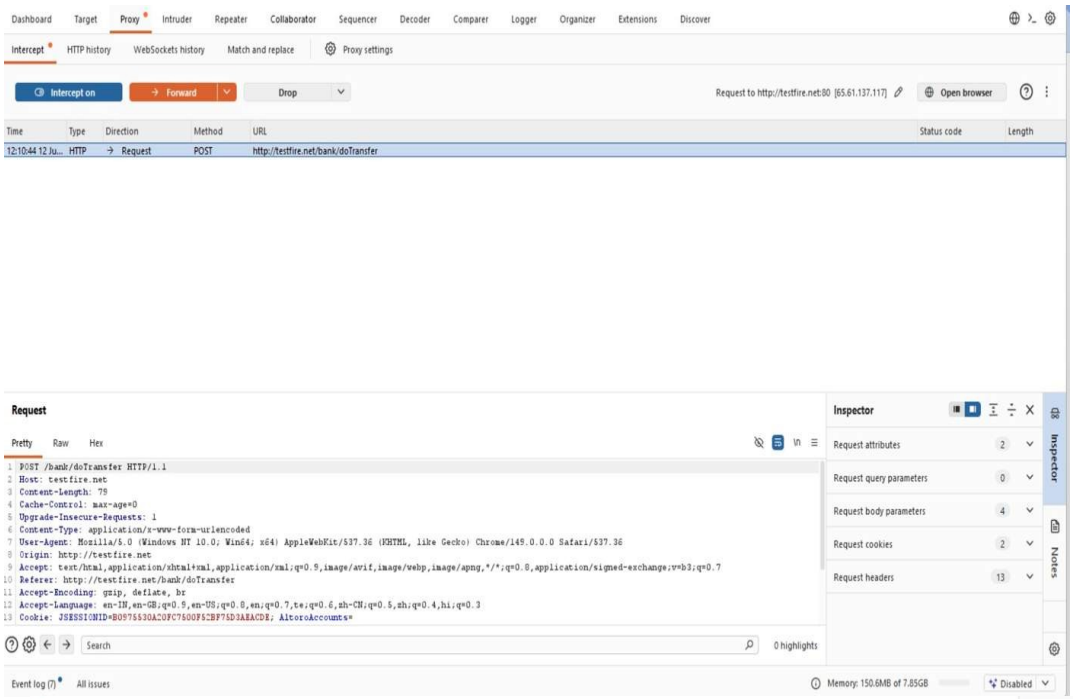
http://testfire.net/bank/doTransfer

Proof of Concept (PoC)

An authenticated user initiated a fund transfer through the application. The HTTP POST request was intercepted using Burp Suite and the transaction amount parameter was modified before being forwarded. The application processed the altered request successfully and confirmed the modified transaction, demonstrating insufficient server-side validation of client-controlled parameters.

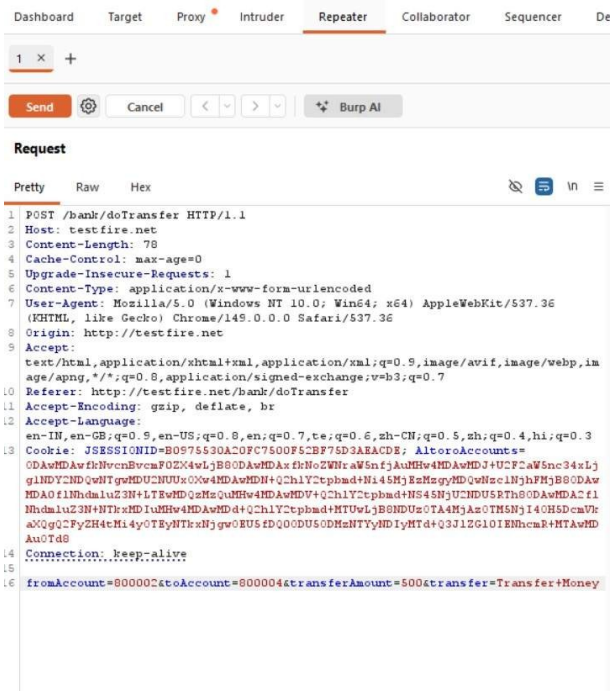


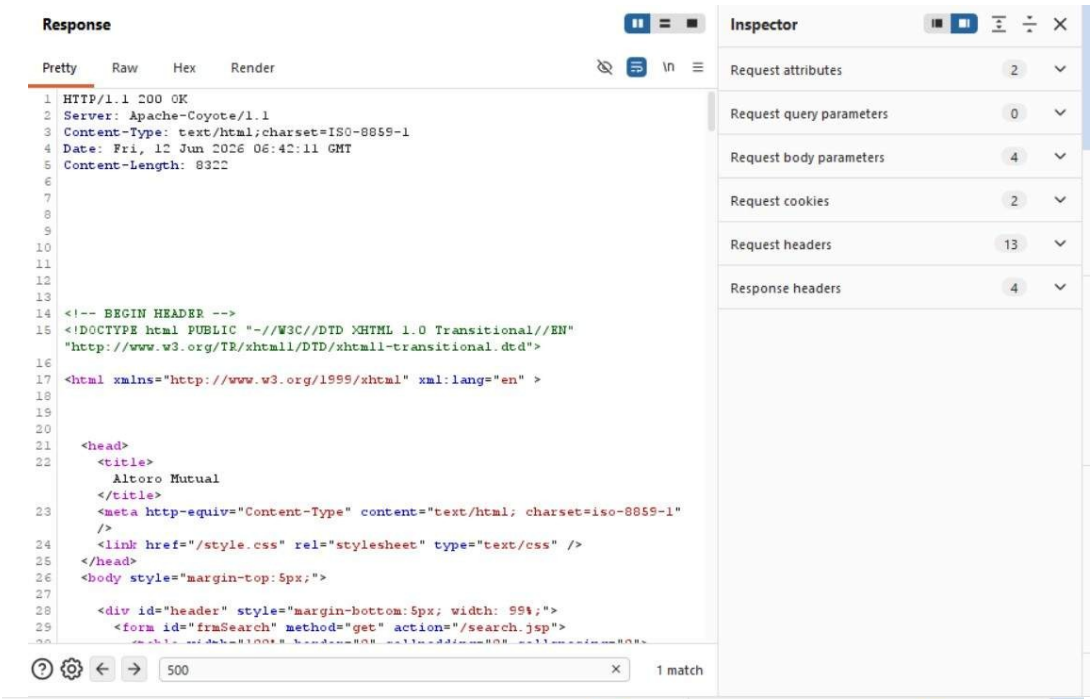


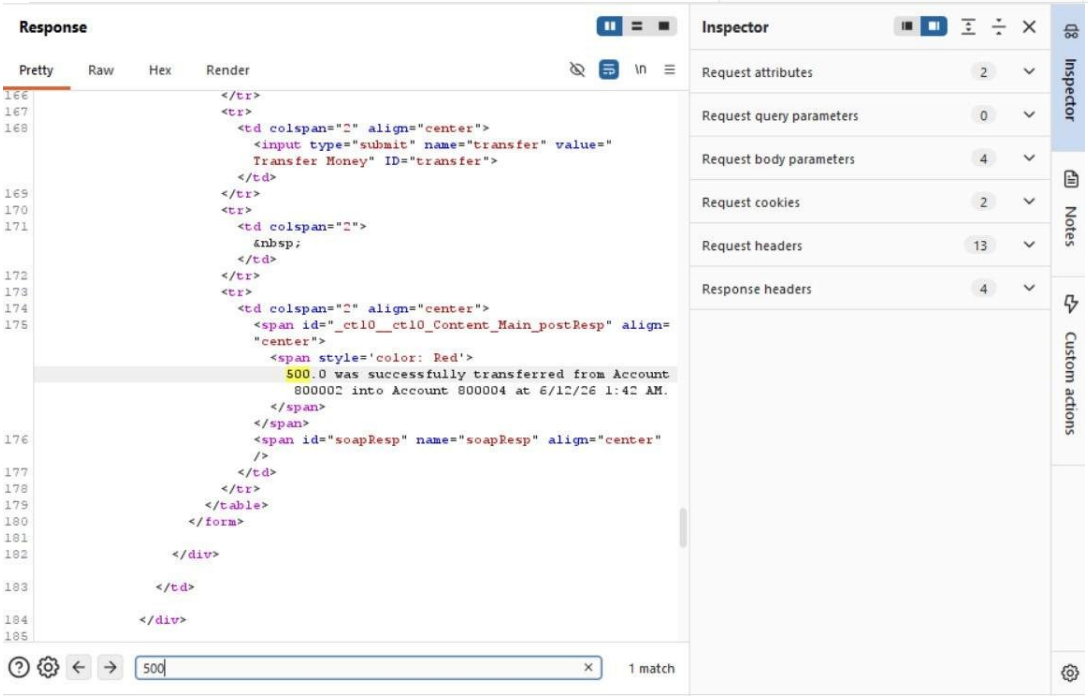

Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Discover
Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings
Intercept on
Forward
Drop
Request to http://testfire.net:80 [65.61.137.117]
Open browser
Time
Type
Direction
Method
URL
Status code
Length
12:10:44 12 Ju...
HTTP
Request
POST
http://testfire.net/bank/doTransfer

Request
Pretty
Raw
Hex
POST /bank/doTransfer HTTP/1.1
Host: testfire.net
Content-Length: 79
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Origin: http://testfire.net
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://testfire.net/bank/doTransfer
Accept-Encoding: gzip, deflate, br
Accept-Language: en-IN,en-GB;q=0.9,en-US;q=0.8,en;q=0.7,te;q=0.6,zh-CN;q=0.5,zh;q=0.4,hi;q=0.3
Cookie: JSESSIONID=B0975530A20FC7500F5CBF75D3AEACDE; AltoroAccounts=
Search
0 highlights
Inspector
Request attributes
2
Request query parameters
0
Request body parameters
4
Request cookies
2
Request headers
13
Inspector
Notes
Event log (7)
All issues
Memory: 150.6MB of 7.85GB
Disabled


Request
Pretty
Raw
Hex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Origin: http://testfire.net
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://testfire.net/bank/doTransfer
Accept-Encoding: gzip, deflate, br
Accept-Language: en-IN,en-GB;q=0.9,en-US;q=0.8,en;q=0.7,te;q=0.6,zh-CN;q=0.5,zh;q=0.4,hi;q=0.3
Cookie: JSESSIONID=B0975530A20FC7500F5CBF75D3AEACDE; AltoroAccounts=
Connection: keep-alive
fromAccount=800002&toAccount=800004&transferAmount=5000&transfer=Transfer+Money
Search
0 highlights
Inspector
Request attributes
2
Request query parameters
0
Request body parameters
4
Request cookies
2
Request headers
13
Inspector
Notes


Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
1
Send
Cancel
Burp AI
Request
Pretty
Raw
Hex
POST /bank/doTransfer HTTP/1.1
Host: testfire.net
Content-Length: 78
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Origin: http://testfire.net
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://testfire.net/bank/doTransfer
Accept-Encoding: gzip, deflate, br
Accept-Language:
en-IN,en-GB;q=0.9,en-US;q=0.8,en;q=0.7,te;q=0.6,zh-CN;q=0.5,zh;q=0.4,hi;q=0.3
Cookie: JSESSIONID=B0975530A20FC7500F5CBF75D3AEACDE; AltoroAccounts=
Connection: keep-alive
fromAccount=800002&toAccount=800004&transferAmount=500&transfer=Transfer+Money





Remediation

1. Perform server-side validation of all transaction parameters.
2. Do not trust client-supplied values for sensitive operations.
3. Recalculate transaction details on the server before processing.
4. Validate user authorization for source and destination accounts.
5. Log and monitor abnormal transaction modifications.
6. Implement anti-tampering controls and integrity checks for critical requests.